



Federal Office
for Information Security

Technical Guideline BSI TR-03145

Secure CA operation

Part 4: Specific requirements for a Certification Authority in a Public Key Infrastructure for the Extended Access Control of the German Official Travel Documents according to BSI TR-03110

Version 2.0.0

08.08.2025



Federal Office for Information Security
P.O. Box 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: eID@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Federal Office for Information Security 2025

Table of Contents

1	Introduction.....	5
1.1	Scope and structure of this document	5
2	General requirements for Certification Authorities.....	6
2.1	Cryptographic measures (Section 2.1 of (BSI-TR-03145-1))	6
2.2	Certification practice statement and certificate policy management (Section 2.2 of (BSI-TR-03145-1))	6
2.2.1	Certificate policy management (Section 2.2.1 of (BSI-TR-03145-1))	6
2.3	Operational security (Section 2.7 of (BSI-TR-03145-1)).....	7
2.4	Audit journal security and archiving (Section 2.12 of (BSI-TR-03145-1)).....	7
2.5	Controlled CA termination (Section 2.13 of (BSI-TR-03145-1)).....	8
3	Key life cycle management.....	9
3.1	CA key life cycle management (Section 3.1 of (BSI-TR-03145-1)).....	9
3.1.1	CA key generation (Section 3.1.1 of (BSI-TR-03145-1))	9
3.1.2	CA key storage, backup, and recovery (Section 3.1.2 of (BSI-TR-03145-1))	9
3.1.3	CA key usage (Section 3.1.4 of (BSI-TR-03145-1)).....	9
3.2	Subject key life cycle management (Section 3.2 of (BSI-TR-03145-1)).....	10
3.2.1	Subject key generation and distribution (Section 3.2.1 of (BSI-TR-03145-1)).....	10
3.2.2	Subject key storage, backup and recovery (Section 3.2.2 of (BSI-TR-03145-1)).....	10
3.2.3	Hardware token life cycle management (not supported) (Section 3.2.3 of (BSI-TR-03145-1)).....	10
3.2.4	Subject key archival and destruction (not supported) (Section 3.2.4 of (BSI-TR-03145-1))	10
4	Certificate life cycle management	11
4.1	Subject registration (Section 4.1 of (BSI-TR-03145-1)).....	11
4.2	Certificate renewal (not supported) (Section 4.2 of (BSI-TR-03145-1)).....	11
4.3	Certificate rekey (Section 4.3 of (BSI-TR-03145-1)).....	11
4.4	Certificate issuance (Section 4.4 of (BSI-TR-03145-1)).....	11
4.5	Certificate distribution (Section 4.5 of (BSI-TR-03145-1)).....	12
4.5.1	Repository (Section 4.5.1 of (BSI-TR-03145-1)).....	12
4.6	Certificate changeover (Section 4.6 of (BSI-TR-03145-1))	12
4.7	Certificate revocation (Section 4.7 of (BSI-TR-03145-1))	13
4.8	Certificate or subscriber suspension (Section 4.8 of (BSI-TR-03145-1))	13
4.9	Revocation status information service (Section 4.9 of (BSI-TR-03145-1))	14
4.10	Validation Model (Section 4.10 of (BSI-TR-03145-1)).....	15
5	Annex: Revocation Service for the eID application.....	16
	Bibliography	17

Abbreviations, definitions and keywords

Table 1: Abbreviations and Definitions

below contains abbreviations and definitions of terms relevant for this document.

Abbreviation	Definition
CVCA-PKI	PKI for the Extended Access Control of the German Official Travel Documents according to [TR-03110].
CVCA	Country Verifying Certificate Authority; the root-CA in the CVCA-PKI
DV	Document Verifier; a sub-CA in the CVCA-PKI
BerCA	“Berechtigungs”-CA, a DV issuing certificates for the eID application (electronic identity) of the German eID scheme (see [TR-03110]).
MDS	Metadata Signer

Table 1: Abbreviations and Definitions

The key words “MUST,” “MUST NOT,” “REQUIRED,” “SHALL,” “SHALL NOT,” “SHOULD,” “SHOULD NOT,” “RECOMMENDED,” “MAY,” and “OPTIONAL” in this document are to be interpreted as described in (RFC2119). Irrespective of capitalisation, the same holds for all referenced “control procedures” of (ISO27099).

1 Introduction

This document is Part 4 of the Technical Guideline series (BSI-TR-03145) and defines requirements for the operation of a Certification Authority with security level 'high'. The document series compiles requirements for a Certification Authority (CA) in a Public Key infrastructure (PKI) with security level 'high' according to Technical Guideline (BSI-TR-03107).

Part 1 considers generic requirements for secure operation of a CA with security level 'high'. The other parts of the series consider additional or modified requirements for specific business cases of PKI.

This document, part 4 of (BSI-TR-03145), defines requirements being specific for the secure operation of the Public Key infrastructure for the Extended Access Control of the German Official Travel Documents according to (BSI-TR-03110)¹.

1.1 Scope and structure of this document

This document concerns the PKI for the Extended Access Control of the German Official Travel Documents, named CVCA-PKI in the following. The CVCA consists of a root-CA, called Country Verifying Certificate Authority (CVCA) and one or more sub-CAs, called Document Verifier (DV).

This document is Part 4 of (BSI-TR-03145) and contains necessary refinements and additions for the specific needs of all Certification Authorities in the CVCA-PKI. In order to be compliant to this document all Certification Authorities in the CVCA-PKI SHALL fulfil all requirements of part 1 of (BSI-TR-03145) which are not refined or discarded here in Part 4 and the additional requirements of Part 4.

In this document the general term CA is used if a requirement applies to both, CVCA and DVs. If requirements do not apply to both or might differ, it will be mentioned explicitly. Furthermore, the requirements in this document apply to CAs in the PKI for the German eID application (CVCA-eID PKI), the German ePass application (CVCA-ePass PKI) and the German eSign application (CVCA-eSign PKI). If requirements do not apply to all these applications or might differ, it will be mentioned explicitly. There are two types of certificates in the CVCA-eID PKI: Card Verifiable certificates (CV certificates) and Meta Data Signer certificates (MDS certificates). If not stated otherwise, the requirements in this document apply to both, CV and MDS certificates.

Note: This document reflects requirements of the root-CA's Certificate Policies of the CVCA-PKI² in order to enable conformance to part 4 of (BSI-TR-03145) and the mentioned Certificate Policies as well, but it does neither replace nor comprise entirely the requirements of the Certificate Policies or regulations by law.

This document contains three types of requirements:

- requirements from (BSI-TR-03145-1) refined for application in the CVCA-PKI;
- requirements from (BSI-TR-03145-1) which are not applicable in the CVCA-PKI;
- requirements in addition to (BSI-TR-03145-1) to be used in the CVCA-PKI.

Annex 5 contains additional requirements which only concern and are normative to those DVs issuing certificates for the eID application of the German eID scheme. Those DVs are called "BerCAs".

¹ For an introduction to this special kind of PKI please refer to [TR-03110].

² Namely the CVCA-eID, the CVCA-ePass and the CVCA-eSign.

2 General requirements for Certification Authorities

2.1 Cryptographic measures (Section 2.1 of (BSI-TR-03145-1))

The following requirement from (BSI-TR-03145-1) concerning cryptographic measures is refined as follows:

2.1A1 The CA SHALL ensure that the cryptographic algorithms and their parameters comply with the newest editions of (BSI-TR-03116-2).

The CA SHALL check the cryptographic algorithms and their parameters referring to the newest editions:

- Each time a cryptographic algorithm is newly implemented.
- When an incident of a used algorithm becomes public.
- Regularly, in a period of [assignment: number of days, weeks or months].

2.2 Certification practice statement and certificate policy management (Section 2.2 of (BSI-TR-03145-1))

2.2.1 Certificate policy management (Section 2.2.1 of (BSI-TR-03145-1))

The following requirement from (BSI-TR-03145-1) concerning the management of the Certificate Policy is refined as follows:

2.2.1A2 The CP SHALL specify the key and certificate management life cycle processes of the CA comprehensively. At least the following aspects SHALL be covered:

- reference to a document owner for CP related issues
- unique document identification for further reference, i.e. by exact document title, version and unique policy identifier for reference in certificates issued by the CA
- limitations concerning subscribers of the PKI (e.g. company or administration specific PKIs)
- application context of the PKI
- description of subscriber registration procedures including specification of registration data, requirements for data transmission, and description of verification procedures of the CA or RA
- subscriber obligations (e.g. requirements on subscriber key stores and application environment)
- specification of certificate profiles and request format
- validation model of the PKI, need of certificate validation by checking signature and fingerprints
- certificate revocation procedures including revocation reasons, revocation authorization, revocation application mechanisms (if supported)
- certificate status information services
 - CRLs (if supported)
 - OCSP (if supported)
- directory service (if supported)
- key lifecycle security measures
- CA termination
- CP update procedures

2.3 Operational security (Section 2.7 of (BSI-TR-03145-1))

The following requirements from (BSI-TR-03145-1) concerning the operational security and the availability of services in particular are refined as follows:

- 2.7A1** The CA shall provide a degree of availability of its services towards its subscribers tailored appropriate to the interval of certificate issuing.
- 2.7A6** The CA shall define the maximal down time of each service and tailor the services appropriately. Particularly the service treating the suspension of certificates shall ensure to process inquiries and updates within [assignment: *number of hours*] hours.

2.4 Audit journal security and archiving (Section 2.12 of (BSI-TR-03145-1))

Control procedure (8) from Section 7.12 of (ISO27099) is refined as follows:

- 2.12R1** The CA SHALL record the information concerning certificate application. This SHALL include:
- the method of identification applied, and information used to meet “know-your-customer” requirements;
 - identification and registration data as defined in the corresponding CP;
 - identity of entity accepting the application as defined in the corresponding CP;
 - validation of identification documents as defined in the corresponding CP;
 - name of receiving CA or submitting RA;
 - the subject’s acceptance of the subscriber agreement.

Control procedure (9) from Section 7.12 of (ISO27099) is refined as follows:

- 2.12R2** The CA SHALL log events concerning the certificate life cycle management. This SHALL include:
- certificate requests;
 - rekey requests;
 - submissions of public keys for certification;
 - change of registration information of an entity;
 - generation and distribution of certificates;
 - distribution of the CA’s public key;
 - requests for certificate revocation or suspension;
 - revocation of a certificate that has been issued by the CA;
 - certificate suspension requests (if supported);
 - certificate suspension and reactivation (if supported);
 - generation and issuance of certificate revocation lists (if supported).

The following requirements from (BSI-TR-03145-1) concerning the logging and archiving of information are refined as follows:

- 2.12A4** The set of information to be archived and the period of time for keeping the archived information SHALL be defined in the CA’s CP. For each event to be archived, the event time SHALL be recorded precisely.

2.5 Controlled CA termination (Section 2.13 of (BSI-TR-03145-1))

Control procedure (7) from Section 7.15.9 of (ISO27099) only applies to the CVCA-eID PKI concerning Metadata Signer Certificates and does not apply to the CVCA-eSign and CVCA-ePass PKIs.

Control procedure (9) from Section 7.15.9 of (ISO27099) is refined as follows:

- 2.13R1** The sub-CA SHALL inform subscribers, subjects and the root-CA as well as other entities the sub-CA has agreements with about successor instances (i.e. third party service providers) prior to its termination. Therefore, the process of the CA termination SHALL be described in the CA's Terms and Conditions.
- 2.13R2** If a subscriber of a CA declares the termination of its business within the PKI, the subscriber SHALL be suspended by its CA at the termination date.
- 2.13R3** If a subscriber of a CA declares the termination of its business within the PKI, the last certificate which will be issued for that subscriber SHALL not have the end of validity beyond the termination date.

3 Key life cycle management

3.1 CA key life cycle management (Section 3.1 of (BSI-TR-03145-1))

The following requirement from (BSI-TR-03145-1) concerning the key life cycle management of the CA's own keys is refined as follows:

3.1A1 Private keys of the CA shall be generated, held, used and deleted in a security device following the requirements of the Certificate Policy of the root-CA ensuring the claimed security features, including tamper resistance, mitigation of side channels, suitable access control, random number generator and security of cryptographic operations.

3.1.1 CA key generation (Section 3.1.1 of (BSI-TR-03145-1))

According to (BSI-TR-03145-1) control procedure (3) from Section 7.13.1 of (ISO27099) SHALL be fulfilled as requirement. This requirement concerning the generation of the CA's own key pair is refined as stated below:

3.1.1R1 The CA key pair generation SHALL be performed by trustworthy personnel during a key ceremony in a four-eyes principle under the attendance of the key responsible officer in a physically secured environment.

The following requirement concerning the generation of the CA's own keys is refined as follows:

3.1.1A1 The generation of a new key pair and the corresponding CA certificate SHALL be done according to the deadlines defined in the corresponding CP.

The following requirement does not apply to CAs affected by this document:

- control procedure (5) from Section 7.13.1 of (ISO27099)

3.1.2 CA key storage, backup, and recovery (Section 3.1.2 of (BSI-TR-03145-1))

The following requirement concerning the storage, backup and recovery of the CA's own keys is refined as follows:

3.1.2A1 The root-CA SHALL make backups of its keys. Sub-CAs (in case of the CVCA-eID this includes DVs and Terminals) MAY make backups of their keys. The requirements defined in (KLSR) for the corresponding security level SHALL be fulfilled.

3.1.3 CA key usage (Section 3.1.4 of (BSI-TR-03145-1))

Control procedure (2) from Section 7.13.1 of (ISO27099) and which is referenced in Section 3.1.4 of (BSI-TR-03145-1) is refined as follows:

3.1.4R1 The activation of the CA private key SHALL be performed using multifactor authentication using hardware tokens (e.g. smart card and password or PIN).

The following requirements of (BSI-TR-03145-1) do not apply to CAs affected by this document:

- requirement 3.1.4A2

3.2 Subject key life cycle management (Section 3.2 of (BSI-TR-03145-1))

3.2.1 Subject key generation and distribution (Section 3.2.1 of (BSI-TR-03145-1))

3.2.1.1 Subject keys provided by subscriber (Section 3.2.1.1 of (BSI-TR-03145-1))

The following requirement concerning the subject registration is refined as follows:

3.2.1.1A2 The registration data SHALL be clearly defined by the CA and SHALL contain the public key of the subject and all subject attributes that are necessary for the registration process. Certificate requests SHALL comply with the corresponding CP.

3.2.1.2 Subject keys provided by the CA (not supported) (Section 3.2.1.2 of (BSI-TR-03145-1))

It is not allowed within a CVCA PKI that the CA generates the subject's key pair and disseminates it to the subscriber or subject. Therefore, all requirements referenced or contained in Section 3.2.1.2 of (BSI-TR-03145-1) do not apply to CAs affected by this document.

3.2.2 Subject key storage, backup and recovery (Section 3.2.2 of (BSI-TR-03145-1))

3.2.2.1 Subject key storage, backup and recovery services provided by CA (not supported) (Section 3.2.2.1 of (BSI-TR-03145-1))

Subject key storage, backup and recovery services by the CA are not supported within a CVCA PKI. Therefore, all requirements referenced or contained in Section 3.2.2.1 of (BSI-TR-03145-1) do not apply to CAs affected by this document.

3.2.3 Hardware token life cycle management (not supported) (Section 3.2.3 of (BSI-TR-03145-1))

If subject key pair generation is provided by the CA (see section 3.2.1.2), the CA may decide to generate a “personalized” token on which the subject key pair and certificate is stored and which is disseminated to the subscriber. This is not supported within a CVCA PKI. Therefore, all requirements referenced or contained in Section 3.2.3 of (BSI-TR-03145-1) do not apply to CAs affected by this document.

3.2.4 Subject key archival and destruction (not supported) (Section 3.2.4 of (BSI-TR-03145-1))

Archival, storage and destruction services of subject keys are not supported by CAs within a CVCA PKI. Therefore, all requirements referenced or contained in Section 3.2.4 of (BSI-TR-03145-1) do not apply to CAs affected by this document.

4 Certificate life cycle management

4.1 Subject registration (Section 4.1 of (BSI-TR-03145-1))

The following requirement concerning the subject registration is refined as follows:

- 4.1R6** The CA SHALL ensure, that the requesting subject is identified unambiguously before starting the certificate generation process. The CA SHALL verify certificate requests as specified in the corresponding CP. In particular, the CA SHALL validate the signatures on certificate requests for successive certificate.

4.2 Certificate renewal (not supported) (Section 4.2 of (BSI-TR-03145-1))

The renewal of a certificate is defined as extending the validity period of a certificate. The public key of the subscriber and the subscriber information of the certificate are not modified. Renewal of certificates is not allowed within the CVCA PKI. Therefore, all requirements referenced or contained in Section 4.2 of (BSI-TR-03145-1) do not apply to CAs affected by this document.

4.3 Certificate rekey (Section 4.3 of (BSI-TR-03145-1))

Rekeying of a certificate is defined as issuing a new certificate based on a newly generated subscriber key pair and a new validity period. The remaining content of the certificate (i.e. the attributes of the subscriber) stays usually unchanged.

The CVCA CPs of the CVCA-PKI allow rekeying of a certificate based on a rekeying request with a newly generated key pair. Note, that this does not apply to Metadata Signer Certificates (MDS certificates) within the CVCA-eID PKI. MDS certificates are not rekeyed. A new MDS certificate for this subject shall always be requested following the process of initial application. Therefore, the requirements in this section do not apply to MDS certificates and their certificate lifecycle management.

The following requirement from (BSI-TR-03145-1) concerning the rekeying of certificates is refined as follows:

- 4.3A1** For the case of expiring certificates, the CA SHALL define in the CP and/or CPS that a request for the rekeying of a certificate SHALL be submitted according to the time frames defined in the CA's CP. The CA SHALL be able to generate the new certificate within the defined timeframe.

4.4 Certificate issuance (Section 4.4 of (BSI-TR-03145-1))

The following requirement concerning the certificate issuance process is refined as follows:

- 4.4A2** Certificates (german: Berechtigungszertifikate) SHALL include the following attributes which SHALL be verified by the CA:
- Certificate Authority Reference ,
 - Certificate Holder Reference ,
 - type of certificate,
 - public key corresponding to the private key under the subscriber control,
 - period of validity,
 - the sequence number of the certificate,
 - the electronic signature of the issuing authority,

- access rights
- certificate extensions (if applicable).

4.4A2 MDS Certificates SHALL include the following attributes which SHALL be verified by the CA:

- Distinguished Name of Issuer,
- Distinguished Name of Subject,
- public key corresponding to the private key under the subscriber control,
- period of validity,
- the certificate serial number,
- the electronic signature of the issuing authority,
- certificate extensions (if applicable).

The following requirements do not apply to CAs affected by this document:

- control procedure (4) from Section 7.15.4 of (ISO27099)
- requirement **4.4A4**

4.5 Certificate distribution (Section 4.5 of (BSI-TR-03145-1))

4.5.1 Repository (Section 4.5.1 of (BSI-TR-03145-1))

Note that (BSI-TR-03145-1) defines in Section 4.5.1. requirements for the publication of certificates by means of a directory service. For requirements from (BSI-TR-03145-1) that address a directory service and that SHALL be fulfilled as requirement according to this document, the requirements ascribed to a directory service SHALL be fulfilled by a non-public repository which is operated and maintained by the CA.

The following requirements from (BSI-TR-03145-1) are refined as follows:

4.5.1A1 The CA SHALL provide a searchable repository that contains all certificates that are issued by this CA and their certificate status information.

4.5.1A4 The Repository SHALL NOT be publicly accessible.

The following requirement from (BSI-TR-03145-1) does not apply to CAs affected by this document:

- requirement **4.5.1A2**

4.6 Certificate changeover (Section 4.6 of (BSI-TR-03145-1))

In this section requirements concerning the secure transition from a CA certificate to the succeeding CA certificate are defined. Note, that these requirements do not apply to Metadata Signer Certificates (MDS certificates) within the CVCA-eID PKI.

The following requirement concerning the secure transition from a CA certificate to the succeeding CA certificate is refined as follows:

4.6A3 The CA changeover SHALL be performed with an overlap time in compliance with the CA's CP in order to ensure a secure transition from the current to the successor CA certificate. The overlap time starts at the same time as the validity of the successor certificate starts.

Additionally, the following requirements hold:

4.6A7 The CA shall provide an appropriate process for re-keying of a certificate if the process is requested by the subscriber or started by the CA. The CA shall ensure that the request is processed in a timely manner.

The following requirements from (BSI-TR-03145-1) do not apply to CAs affected by this document:

- requirement **4.6A2**
- requirement **4.6A6**

4.7 Certificate revocation (Section 4.7 of (BSI-TR-03145-1))

The requirements in this section concern the revocation of certificates. Note, that within the CVCA-eID PKI only MDS certificates are revoked and only the revocation of MDS certificates is published by means of Certificate Revocation Lists. Therefore, each CA within the CVCA-eID PKI shall provide a revocation service for MDS certificates and shall maintain the revocation status information of MDS certificates. CV certificates within the CVCA-eID are not revoked, incidents are handled via short-term end-user certificates and the suspension of subscribers (see 4.8). Thus, the requirements in this section apply to MDS certificates within the CVCA-eID PKI only.

Control procedure (10) from section 7.15.6 of (ISO27099), which is referenced in (BSI-TR-03145-1), is refined as follows:

4.7R1 The CA SHALL maintain controls to revoke MDS certificates and publish appropriate information about revoked MDS certificates.

Additionally, the following requirements apply:

4.7A10 Revocation lists of MDS certificates SHALL be backed up to a physically separated server to avoid the loss of data.

4.7A11 The integrity of the revocation information SHALL be secured by appropriate means.

4.7A12 The service processing the revocation of certificates SHALL ensure the processing of inquiries and updates as specified in the CA's CP.

4.7A13 The CA SHOULD document and archive each revocation request and actually performed revocation in a comprehensible way. This documentation and archiving SHOULD include at least:

- entity that applied for revocation of a certificate,
- name of revoked subject if present and known at time of revocation,
- serial number of revoked certificate if present and known at time of revocation,
- reasonable evidence for the legitimacy of the revoking party,
- date and time of revocation,
- date and time of invalidity, and
- revocation reason.

4.8 Certificate or subscriber suspension (Section 4.8 of (BSI-TR-03145-1))

The CVCA CPs of the CVCA-PKI intend the suspension of subscribers e.g. in case of incidents. In the case of a subscriber suspension, the CA shall not issue certificates for this subscriber.

Control procedure (5) from section 7.15.7 of (ISO27099), which is referenced in (BSI-TR-03145-1), is refined as follows:

4.8R1 The CA SHALL update the suspension status information upon certificate suspension.

Control procedure (9) from section 7.15.7 of (ISO27099), which is referenced in (BSI-TR-03145-1), is refined as follows:

- 4.8R2** The CA SHALL update the suspension status information upon the lifting of a certificate suspension in accordance with the CA's CP.

Control procedure (13) from section 7.15.7 of (ISO27099), which is referenced in (BSI-TR-03145-1), is refined as follows:

- 4.8R3** The CA SHALL process and update the suspension status information in a period of [assignment: *number of hours*] hours in case of a suspension.

Control procedure (14) from section 7.15.7 of (ISO27099), which is referenced in (BSI-TR-03145-1), is refined as follows:

- 4.8R4** The CA SHALL ensure that the suspension status information is secured against failure, attacks and unauthorized modification. The CA SHALL analyze the risk of a server failure and attacks against the server. If necessary, the IT infrastructure SHALL be deployed redundantly.

The requirements from (BSI-TR-03145-1) concerning suspension are refined as follows:

- 4.8A2** The complete suspension process (i.e. the delay between a suspension request or report and the availability of the suspension status information) SHOULD be at most [assignment: *number of minutes*] minutes.

Additionally, the following requirements apply:

- 4.8A3** The CA SHALL ensure that suspended subscribers will not receive any certificates as long as the suspension is active.
- 4.8A4** The CA SHALL define an appropriate procedure for the suspension started by an authorized subscriber suspension. The involved parties and suspension reasons SHALL be clearly defined. The CA SHALL ensure: 1.) the identification of persons/institutions with legitimate claim to apply for suspension of a subscriber: the subscriber/certificate holder, [assignment: *list of further persons/institutions*], 2.) the identification of reasons for a suspension: private key of certificate compromised, incorrect information on certificate, security incident on the IT systems of the certificate holder/subscriber, subscriber not fulfilling Terms and Conditions of the CA, [assignment: *other reasons for suspension*], 3.) [assignment: *the transmission path and record of the suspension*] 4.) [assignment: *additional requirements for a successful suspension*] 5.) The suspension of a subscriber may only be cancelled, if the cause for the suspension has been solved.
- 4.8A5** The CA SHALL ensure that suspension information are up-to-date and accessible by the registration and the certification processes as well.

The following requirement from (BSI-TR-03145-1) does not apply to CAs affected by this document:

- requirement **4.8A1**

4.9 Revocation status information service (Section 4.9 of (BSI-TR-03145-1))

The following control procedures from Section 7.15.8 of (ISO27099) and which are referenced in Section 4.9 of (BSI-TR-03145-1) concerning the revocation status information service SHALL be fulfilled as requirements with respect to MDS certificates within the CVCA-eID PKI:

(1), (2), (3), (4), (6), (7).

The following control procedure from Section 7.15.8 of (ISO27099) and which is referenced in Section 4.9 of (BSI-TR-03145-1) does not apply to CAs affected by this document:

(5)

Online certificate status mechanisms (e.g. OCSP) SHALL not be used within the CVCA-PKI. Thus the following control procedures from Section 7.15.8 of (ISO27099) and which are referenced in Section 4.9 of (BSI-TR-03145-1) concerning online certificate status mechanisms do not apply to CAs affected by this document:

(9), (10).

The following requirement from (BSI-TR-03145-1) concerning the maintenance of status information of certificates or subscribers is refined as follows:

4.9A1 The CA SHALL ensure that the status information of certificates or subscribers is continuously available and accessible to the relevant parties.

4.10 Validation Model (Section 4.10 of (BSI-TR-03145-1))

The following requirement concerning the validation model is refined as follows:

4.10A2 The Shell Model SHALL be used.

5 Annex: Revocation Service for the eID application³

The Revocation Service for the eID application is a process to prevent the misuse of the eID application with, for example, lost or stolen identity cards or residence permits. Therefore, it only concerns BerCAs.

For details on the Revocation Service for the eID application please refer to (BSI TR-03127).

For BerCAs, the following requirements apply in addition to those of (BSI-TR-03145-1):

- | | |
|---------------|--|
| REVeID.Req.1a | The BerCA SHALL install appropriate technical and organizational measure to ensure the confidentiality of the revocation token at all times. |
| REVeID.Req.2a | The BerCA SHALL generate the key pairs for the revocation lists only within a security area fulfilling the following criteria: separated area, access control, access only for authorized personnel, (ISO27001) certificate covering the security area and the generation and use of the key pairs for the revocation lists. |
| REVeID.Req.3a | The BerCA SHALL delete the outdated eID revocation list. |
| REVeID.Req.4a | The BerCA SHALL compute its service specific revocation list based on DER encoding according to (ITU-T X.690). |

³ Concerns BerCAs only

Bibliography

- BSI-TR-03107 *Bundesamt für Sicherheit in der Informationstechnik: Elektronische Identitäten und Vertrauensdienste im E-Government, Teil 1: Vertrauensniveaus und Mechanismen.*
- BSI-TR-03110 *Bundesamt für Sicherheit in der Informationstechnik: Advanced Security Mechanisms for Machine Readable Travel Documents and eIDAS token.*
- BSI-TR-03116-2 *Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Vorgaben für Projekte der Bundesregierung, Teil 2: Hoheitliche und eID-Dokumente.*
- BSI-TR-03145 *Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation.“*
- BSI-TR-03145-1 *Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation, Part 1: Generic requirements for a Certification Authority in a Public Key Infrastructure with security level 'high'.*
- ISO27001 *ISO/IEC 27001: Information security management systems – Requirements.“ 2022.*
- ISO27099 *ISO/IEC 27099: Information technology – Public key infrastructure – Practices and policy framework.“ 2022.*
- KLSR *Bundesamt für Sicherheit in der Informationstechnik: Key Lifecycle Security Requirements.“*
- RFC2119 *Bradner, S.: Key words for use in RFCs to Indicate Requirement Levels.*
<https://datatracker.ietf.org/doc/html/rfc2119>: IETF.